

Cybersecurity Daily Newsletter

Vol. 002 | 2026-06-19 07:00 WIB

Top 5 Highlights

- Lost in relocation: analysis of a new loader distributing CASTLESTEALER
- Gentlemen ransomware uses multiple EDR killers to disable defenses
- Novo Nordisk Breach Exposes Software Development Pipeline Risk
- VU#457458: Vendor-signed UEFI applications found vulnerable to Secure Boot bypass
- Nintendo confirms data stolen in WebMD subsidiary cyberattack

Threat Intelligence (10)

01. Lost in relocation: analysis of a new loader distributing CASTLESTEALER

Find out how a new obfuscated loader evades static detection using .reloc section abuse, five anti-VM/language checks and MBA obfuscation to deliver infostealer malware via Google Ads.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.elastic.co/security-labs/oxloader-malware-loader-infostealer>

02. USB worm spreads crypto-stealing malware via Windows shortcut files

Threat actors targeting cryptocurrency wallets have been distributing clipboard-stealing malware with self-spreading capabilities and using the Tor network to conceal communication. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/usb-worm-spreads-crypto-stealing-malware-via-windows-shortcut-files/>

03. Police cleans nearly 15,000 SocGholish-infected sites tied to Evil Corp

International law enforcement agencies cleaned nearly 15,000 malware-infected WordPress websites and took down more than 100 servers linked to the SocGholish botnet and the Evil Corp Russian cybercrime group. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/law-enforcement-nukes-socgholish-malware-from-nearly-15-000-sites/>

04. ShapedPlugin update flow hacked to infect WordPress sites

Multiple WordPress plugins from ShapedPlugin were compromised in a supply chain attack that distributed infected releases to paying customers via the vendor's official update system. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.bleepingcomputer.com/news/security/shapedplugin-update-flow-hacked-to-infect-wordpress-sites/>

05. 5 new security operations roles the AI-SOC will create

For years we've heard the frightening prediction that AI will take jobs away from people. It will and it already is, but that doesn't mean it won't also create new jobs and skills demands - like every other labor trend driven by technology advances. Take security operations for example. Historically, security operations centers (SOCs) were built on a three...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources:

<https://www.csoonline.com/article/4186569/5-new-security-operations-roles-the-ai-soc-will-create.html>

06. [+24h Old] Why Account Takeovers Are Rising and How to Stop Them

Account takeovers are rising as attackers bypass traditional defenses through phishing, session hijacking, and MFA fatigue. Specops Software explores how device trust and continuous verification help reduce account takeover risk. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/why-account-takeovers-are-rising-and-how-to-stop-them/>

07. [+24h Old] From Stars to Upvotes: Fake Reputation Fueling a Crypto Clipboard Hijacker

Key Points Introduction In this research, we analyze a clipboard hijacker campaign that is hidden inside a collection of "solutions" and "tools" that claim to give users an unfair advantage. These offers include Solana and Pump.fun sniper bots (automated tools that try to buy new tokens or meme coins faster than other traders), Aviator Predictor [...] The pos...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://research.checkpoint.com/2026/from-stars-to-upvotes-fake-reputation-fueling-a-crypto-clipboard-hijacker/>

08. [+24h Old] 5 AI risk management frameworks for shoring up key gaps

Organizations racing to embed AI into business operations are realizing that the risk management frameworks they've relied on for decades aren't built for the behaviors, failure modes, and ethical complexities AI systems introduce. Fortunately, a new

generation of AI-specific frameworks has emerged to give organizations a structured way to identify where AI...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.csoononline.com/article/4185917/5-ai-risk-management-frameworks-for-shoring-up-key-gaps.html>

09. [+48h Old] Fileless Phantom Stealer Targets Browser Credentials

In addition to executing entirely in memory, the malware's infection chain incorporates other anti-analysis techniques designed to evade detection.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.darkreading.com/cyberattacks-data-breaches/fileless-phantom-stealer-targets-browser-credentials>

10. [+48h Old] SprySOCKS Windows Variant Abuses Kernel Drivers to Evade Detection

FishMonger, a China-nexus threat group, has deployed an undocumented version of the Linux backdoor against government targets in Honduras, Taiwan, Thailand, and Pakistan.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.darkreading.com/threat-intelligence/sprysocks-windows-variant-kernel-drivers>

Latest Vulnerabilities (10)

01. VU#457458: Vendor-signed UEFI applications found vulnerable to Secure Boot bypass

Overview Multiple vendor-signed UEFI applications are vulnerable to Secure Boot bypass via a "Bring Your Own Vulnerable Driver" (BYOVD)-style attack. If a target system trusts the affected vendor's certificate, an attacker can exploit these applications to execute arbitrary code during the early pre-boot phase before the operating system initializes. To mit...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://kb.cert.org/vuls/id/457458>

02. FIFA Bug Exposes World Cup Streams to Remote Takeover

A hacker could have "Rickrolled" the World Cup - or worse - thanks to FIFA's unenforced Entra access controls.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.darkreading.com/application-security/fifa-bug-world-cup-streams-remote-takeover>

03. Build your own vulnerability harness

We break down the technical architecture behind our multi-stage vulnerability discovery harness and automated triage loop. Learn how we manage state controls, squash false positives through adversarial review, and route around LLM context limits.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://blog.cloudflare.com/build-your-own-vulnerability-harness/>

04. Salesforce Data Thefts Continue via Klue App Compromise

Klue's Battlecards is now the third integrated application that has been compromised to steal customers' Salesforce data, and victims include Huntress, the cybersecurity vendor.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.darkreading.com/cyberattacks-data-breaches/salesforce-data-thefts-klue-app-compromise>

05. Attackers abuse Google Ads, GitLab, and Claude to deliver malware

Threat actors are abusing trusted platforms, including Google Ads, GitLab pages, and Claude's shared chat feature, to trick users into executing malicious commands on their systems. Disguised as popular AI developer tools, the threat actors used ClickFix social engineering attacks, where victims were tricked into manually executing malicious commands. Typic...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4186813/attackers-abuse-google-ads-gitlab-and-claude-to-deliver-malware.html>

06. Apple fixes Beats Studio Buds flaw that let hackers spy on conversations

Apple has released security updates to patch a high-severity flaw affecting the Beats Studio Buds wireless earbuds that could allow attackers in Bluetooth range to spy on users' conversations. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/apple-fixes-beats-studio-buds-flaw-that-let-hackers-spy-on-conversations/>

07. F5 issues out-of-band patches for critical NGINX vulnerabilities

Cybersecurity company F5 has released out-of-band security updates to address multiple NGINX web server vulnerabilities, including two critical-severity flaws that could allow attackers to execute code on vulnerable systems. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/f5-issues-out-of-band-patches-for-critical-nginx-vulnerabilities/>

08. FortiBleed campaign exposes 75,000 Fortinet firewalls worldwide

A massive credential-compromise campaign dubbed “Fortibleed” has been found to expose tens of thousands of Fortinet devices worldwide, with researchers warning of persistent attacker access to affected enterprise environments. The campaign was first flagged by security researcher Volodymyr Diachenko, who posted on LinkedIn about finding an attacker-controll...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoononline.com/article/4186790/fortibleed-campaign-exposes-75000-fortinet-firewalls-worldwide.html>

09. Cybersecurity was built for predictable systems. AI changes the rules

Every major technology shift changes cybersecurity. I've spent much of my career working through major technology transitions, from the rise of the commercial internet to mobile and cloud computing. Each shift created new opportunities for innovation, but it also created new security problems organizations weren't fully prepared for. AI may resemble previou...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoononline.com/article/4186374/cybersecurity-was-built-for-predictable-systems-ai-changes-the-rules.html>

10. [+24h Old] VU#380058: SignalRGB kernel driver contains improper access control and IOCTL vulnerabilities

Overview The SignalRGB kernel driver, Signallo.sys , contains two vulnerabilities involving improper access control and unsafe memory handling. The device object is created with an overly permissive Discretionary Access Control List (DACL) that allows user-mode processes to access privileged hardware operations through input/output control (IOCTL) commands....

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://kb.cert.org/vuls/id/380058>

Data Breach & Cybercrime (10)

01. Gentlemen ransomware uses multiple EDR killers to disable defenses

The Gentlemen ransomware-as-a-service (RaaS) is actively developing and maintaining a suite of endpoint detection and response (EDR) killers to help affiliates evade detection in attacks. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/gentlemen-ransomware-uses-multiple-edr-killers-to-disable-defenses/>

02. Novo Nordisk Breach Exposes Software Development Pipeline Risk

A leaked GitHub token underscores what most organizations get wrong: Treating secrets management as a tooling problem rather than an identity problem.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.darkreading.com/cyber-risk/novo-nordisk-breach-exposes-dev-pipeline-risk>

03. Nintendo confirms data stolen in WebMD subsidiary cyberattack

Nintendo of America has confirmed to BleepingComputer that threat actors stole survey data from the third-party TinyPulse service used internally, but its systems were not compromised. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/nintendo-confirms-data-stolen-in-webmd-sub-sidiary-cyberattack/>

04. Klue OAuth breach linked to 'Icarus' Salesforce data theft attacks

Market intelligence platform Klue suffered a OAuth breach that enabled the "Icarus" threat actors to steal Salesforce CRM data from multiple organizations in an ongoing extortion campaign. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/klue-oauth-breach-linked-to-icarus-salesforce-data-theft-attacks/>

05. FortiBleed leak exposes Fortinet VPN credentials for 73,000 devices.

A newly discovered data leak dubbed "FortiBleed" has exposed what appears to be a collection of Fortinet and FortiGate VPN credentials for 73,932 firewall URLs at organizations worldwide. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/fortibleed-leak-exposes-fortinet-vpn-credentials-for-73-000-devices/>

06. Telegram admits it couldn't police exam-leak channels, India tells court

India's government has told the Delhi High Court that Telegram was warned about two weeks before it was blocked, and that the platform admitted it could not proactively detect the channels selling leaked exam papers. Telegram says it cooperated and the ban is unlawful. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/telegram-admits-it-couldnt-police-exam-leak-channels-india-tells-court/>

07. New CISO appointments 2026

The upper ranks of corporate security are seeing a high rate of change as companies try to adapt to the evolving threat landscape. Many companies are hiring a chief security officer (CSO) or chief information security officer (CISO) for the first time to support a deeper commitment to information security. Follow this column to keep up with new appointments...

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.csoononline.com/article/4186743/new-ciso-appointments-2026.html>

08. Leak confirms OpenAI is testing a ChatGPT for Science subscription

OpenAI appears to be testing a new subscription and experience for science use cases, but it's unclear if it'll be available to everyone regardless of their background. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/artificial-intelligence/leak-confirms-openai-is-testing-a-chatgpt-for-science-subscription/>

09. [+24h Old] INC Ransomware Thrives by Mastering the Basics

And one of those basics is focusing on sectors where a ransomware disruption creates immediate pressure to pay up, like with healthcare.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.darkreading.com/cyberattacks-data-breaches/inc-ransomware-thrives-by-mastering-the-basics>

10. [+24h Old] India's Telegram ban hit the UAE too. Here's how to get around it

India has banned Telegram until June 22 after the app was used to circulate leaked exam papers. CEO Pavel Durov accuses telecom Reliance of BGP hijacking that disrupted the app as far away as the UAE. Here's what happened, and how to get around the block with an MTProto proxy. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/indias-telegram-ban-hit-the-uae-too-heres-how-to-get-around-it/>